PROFESSIONAL ETHICAL HACKING TRACK · PEHT

MODULE 05

Network Discovery and Mapping

```
>_ nmap -sS -sV -O 192.168.56.102
```

INSTRUCTOR

Mo'tasem Abu Baha'

CYBERA4U
CYBER ACADEMY FOR U

>_ MODULE 05 ROADMAP

Eight lessons, one scanning workflow

01 

Concepts of Network Discovery

02 

Common Discovery Tools

03 

Identifying Live Hosts

04 

Open Ports & Running Services

05 

Operating Systems & Versions

06 

Bypassing Detection Systems

07 

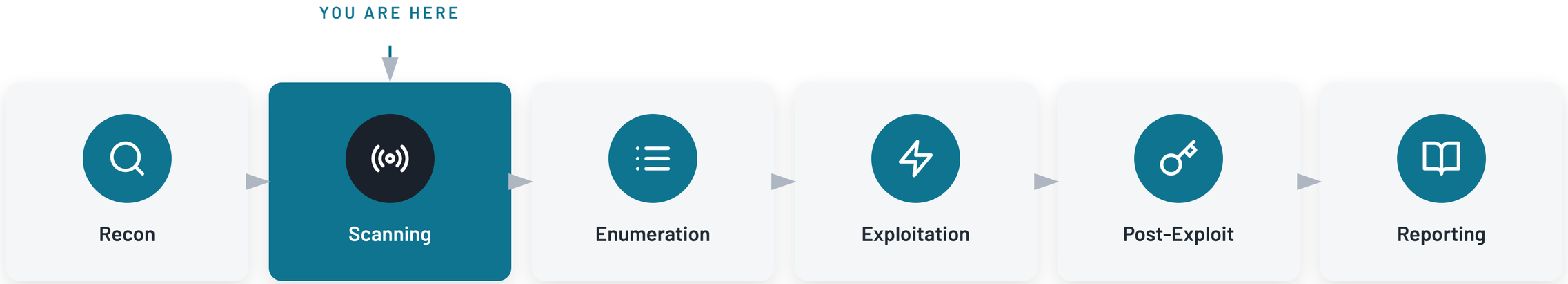
Manipulating Source Traffic

08 

Defensive Measures

CYBERA4U
CYBER ACADEMY FOR U

Discovery comes right after reconnaissance



Module 05 turns the IP ranges found in recon into a live map of **hosts, ports, services and operating systems**.

CYBERA4U
CYBER ACADEMY FOR U

>_ RULES OF ENGAGEMENT

Scan only what you are authorized to scan

IN SCOPE — THE LAB

- **Kali Linux attacker**
  192.168.56.101
- **Metasploitable 2 target**
  192.168.56.102
- **Host-only lab network**
  192.168.56.0/24

OUT OF SCOPE

- **Any public / third-party IP**
  The internet is never a target
- **Systems without written permission**
  No consent means no scan
- **Production or client assets**
  Unless explicitly authorized

Active scanning is intrusive. Every command in this module runs against the lab, with written permission.

CYBERA4U
CYBER ACADEMY FOR U

>_ MODULE LEARNING OBJECTIVES

By the end of this module you will...



Discover which hosts are alive

Sweep a subnet at layer 2 and layer 3



Map open ports and running services

Choose and read TCP, UDP and stealth scans



Fingerprint operating systems and versions

Match a software version to attack surface



Test detection and evasion safely

Measure a scan's footprint against defenses



Defend against network discovery

Detect, slow down and reduce exposure

CYBERA4U
CYBER ACADEMY FOR U

>_

LESSON 01

Concepts of Network Discovery

CYBERA4U
CYBER ACADEMY FOR U

From an IP range to a map of the target

INPUT

192.168.56.0/24

a range of addresses



OUTPUT — A STRUCTURED PICTURE OF THE NETWORK

Live hosts

which IPs answer

Open ports

where services listen

Services & versions

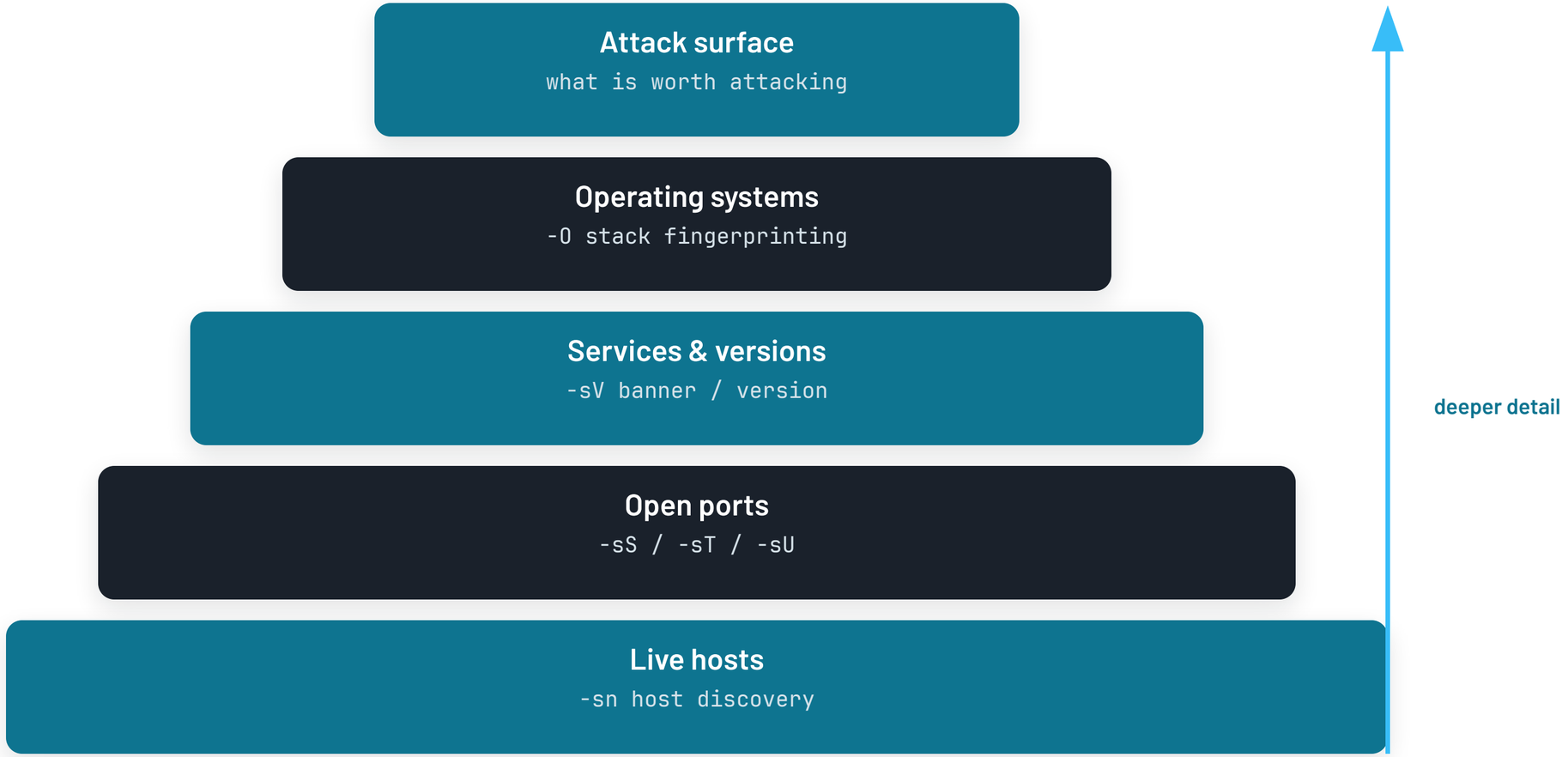
what software is running

Attack surface

what is worth testing

CYBERA4U
CYBER ACADEMY FOR U

Each answer builds on the one below it



Louder scans reveal more — and risk more

PASSIVE

+ Observe only — never send probes
+ Very hard to detect
+ Limited, indirect data

ACTIVE (this module)

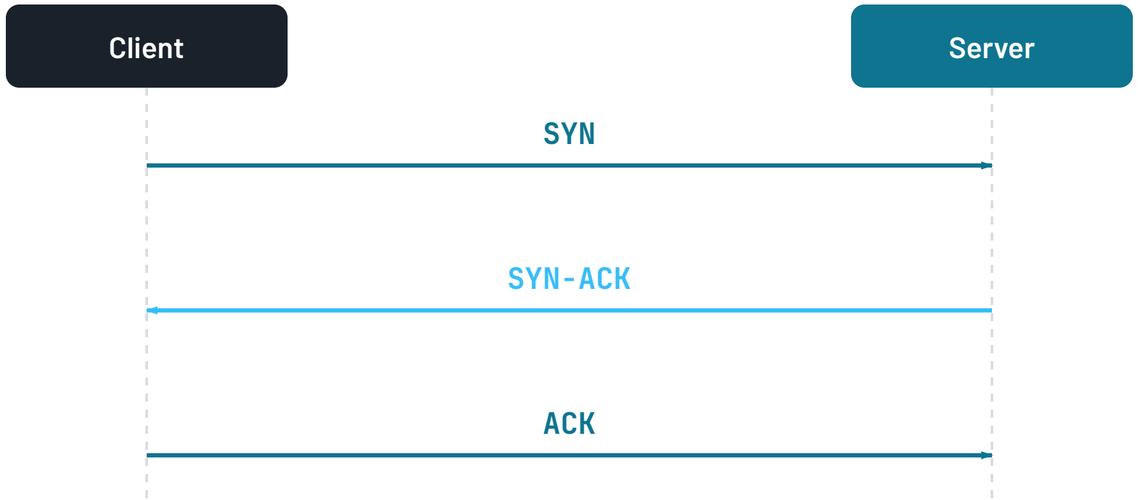
+ Send probes, then read the replies
+ Rich, precise data
+ Noisy — it can be detected

THE TRADE-OFF

quieter · less data — louder · more data · more risk

CYBERA4U
CYBER ACADEMY FOR U

The 3-way handshake every scan builds on



TCP connection established → data can flow

TCP

Connection-oriented · reliable · handshake before any data moves

UDP

Connectionless · no handshake · faster, with no delivery guarantee

Scans manipulate these flags to learn a port's state without ever completing a connection.

CYBERA4U
CYBER ACADEMY FOR U

Ports have ranges — and ports have states

PORT RANGES

Range	Ports	Examples
Well-known	`0 – 1023`	`22, 80, 443`
Registered	`1024 – 49151`	`3306, 8080`
Dynamic	`49152 – 65535`	`ephemeral`

PORT STATES

`open`
Service is listening and accepting

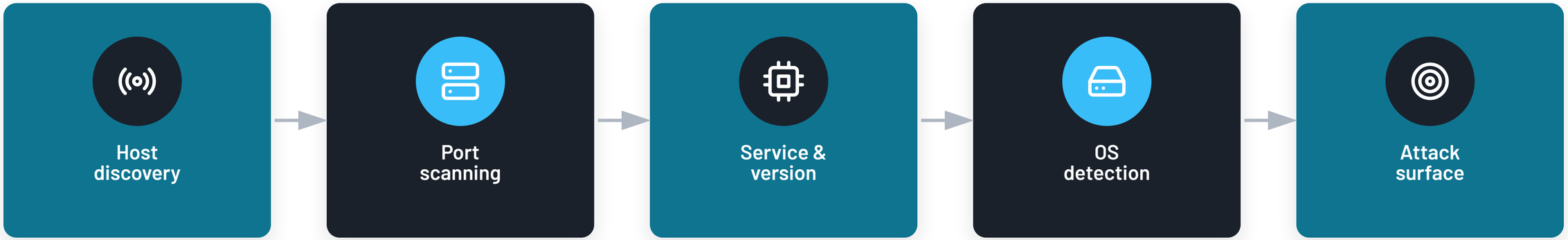
`closed`
Reachable, but nothing is listening

`filtered`
A firewall is blocking the probe

Nmap also reports unfiltered, and the blended state open|filtered when it cannot be certain.

CYBERA4U
CYBER ACADEMY FOR U

The discovery workflow we follow throughout



Lessons 03 → 06 walk this chain one step at a time.

CYBERA4U
CYBER ACADEMY FOR U

Your turn — run it against the lab

```
TARGET Metasploitable 2 @ 192.168.56.102 NETWORK 192.168.56.0/24 (host-only)
```

1. List the lab subnet and confirm your Kali IP with ip addr.
2. Explain, in one line, why discovery follows reconnaissance.
3. Name the three TCP handshake packets, in order.
4. Classify ports 22, 8080 and 52000 by their range.
5. Define the open, closed and filtered port states.

No solutions on this slide — work through each task on your own Kali VM.

CYBERA4U
CYBER ACADEMY FOR U

Three things to remember

1

Discovery turns a range into a map

Hosts → ports → services → OS → attack surface

2

Active scanning is loud by design

More data always comes with more risk of detection

3

Port state is the core signal

open, closed and filtered drive every later decision

CYBERA4U
CYBER ACADEMY FOR U

>_

LESSON 02

Common Discovery Tools

CYBERA4U
CYBER ACADEMY FOR U

Six tools, one job: find what is out there

Nmap
The all-in-one scanner

Netdiscover
Interactive ARP discovery

ARP-scan
Fast layer-2 host sweep

Masscan
Internet-scale speed

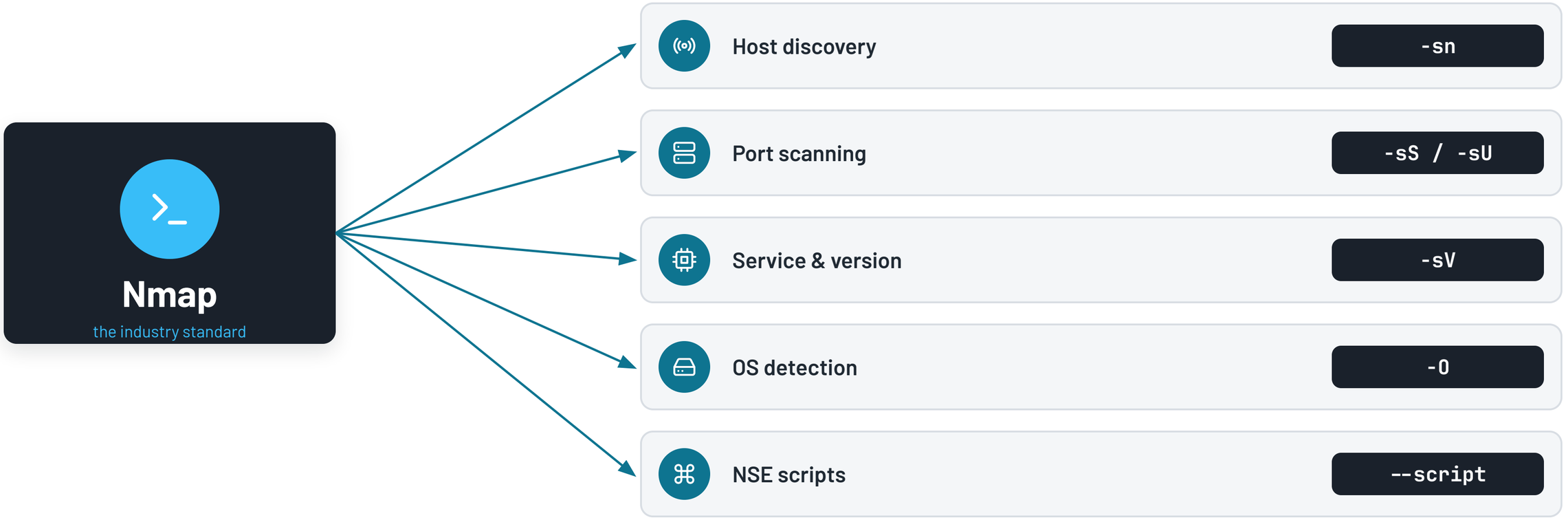
fping
Scriptable ICMP sweeps

hping3
Hand-crafted packets

Each has a niche — but Nmap covers the whole discovery workflow in one place.

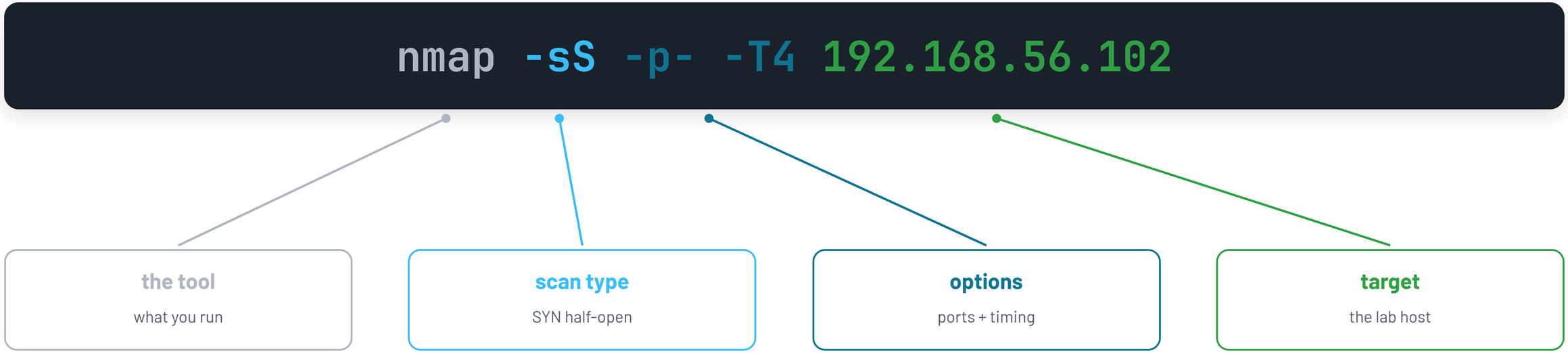
CYBERA4U
CYBER ACADEMY FOR U

One tool for the whole discovery workflow



CYBERA4U
CYBER ACADEMY FOR U

Every Nmap scan has the same shape




```
nmap [scan type] [options] [target]
```


CYBERA4U
CYBER ACADEMY FOR U

Four ways to point Nmap at the lab

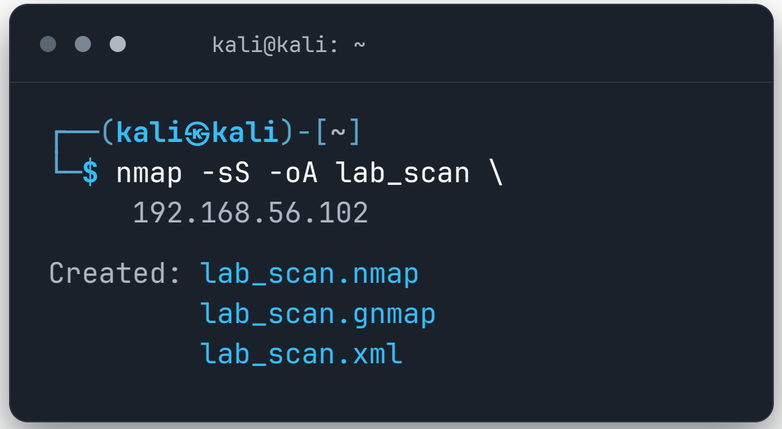
Target type	Example (lab)	What it scans
Single host	`192.168.56.102`	One Metasploitable 2 box
Address range	`192.168.56.100-110`	A slice of the subnet
CIDR subnet	`192.168.56.0/24`	The whole host-only network
From a file	`-iL hosts.txt`	A saved list of targets

Exclude hosts with **`--exclude`** or **`--excludefile`** to protect out-of-scope IPs.

CYBERA4U
CYBER ACADEMY FOR U

Always save your scan output

Flag	Format	Reach for it when…
`-oN`	Normal	You want a human-readable log
`-oG`	Grepable	You will grep / awk the results
`-oX`	XML	A tool or report will parse it
`-oA`	All three	You just want everything saved



`-oA <name>` writes all three at once — make it a habit.

CYBERA4U
CYBER ACADEMY FOR U

Dial the speed with -T0 through -T5

QUIETER / SLOWER

NOISIER / FASTER



`-T4` is the sweet spot inside a fast, isolated lab

`-T0 / -T1` go slow to stay quiet against sensors

`-v` adds verbosity;

-vv shows results as they arrive, live.

CYBERA4U
CYBER ACADEMY FOR U

Your turn — run it against the lab

```
TARGET Metasploitable 2 @ 192.168.56.102 NETWORK 192.168.56.0/24 (host-only)
```

1. Run netdiscover and arp-scan -l on the lab segment.
2. Build an Nmap command using scan type, options and target.
3. Scan 192.168.56.102 and save results with -oA lab02.
4. Repeat the scan with -T4 and with -T1; compare the time.
5. Open the .nmap and .gnmap files and compare their format.

No solutions on this slide — work through each task on your own Kali VM.

CYBERA4U
CYBER ACADEMY FOR U

Three things to remember

1

Nmap is the backbone

One tool does hosts, ports, versions, OS and scripts

2

Every command is type + options + target

Learn the shape once; reuse it everywhere

3

Always save output

-oA keeps a normal, grepable and XML record

CYBERA4U
CYBER ACADEMY FOR U

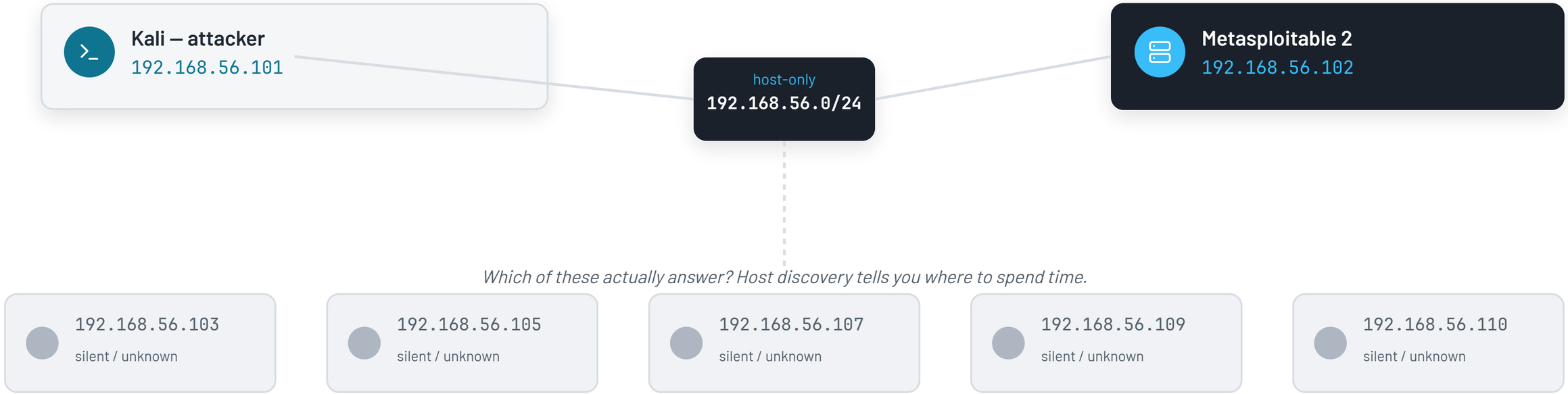
>_

LESSON 03

Identifying Live Hosts

CYBERA4U
CYBER ACADEMY FOR U

Find the live hosts before scanning ports



CYBERA4U
CYBER ACADEMY FOR U

On the local segment, ARP is king

```
kali@kali: ~

┌──(kali㉿kali)-[~]
└─$ sudo arp-scan -l
Interface: eth1, 192.168.56.0/24
192.168.56.1    0a:00:27:00:00:00   (Unknown)
192.168.56.102  08:00:27:a1:b2:c3   (VirtualBox)

2 packets received by filter, 0 dropped
```

Why layer 2?

+ ARP cannot be firewalled off-LAN
+ Every live host must answer ARP
+ Reveals the MAC vendor (VirtualBox)

`netdiscover` does the same job interactively, watching ARP traffic in real time.

CYBERA4U
CYBER ACADEMY FOR U

Ping-sweep the subnet with -sn

kali@kali: ~

```
┌──(kali㉿kali)-[~]
└─$ nmap -sn 192.168.56.0/24
Nmap scan report for 192.168.56.101
Host is up (0.00042s latency).
Nmap scan report for 192.168.56.102
Host is up (0.00058s latency).
Nmap done: 256 IPs (2 hosts up) scanned
```

-sn = "ping scan": discover live hosts, then **skip the port scan**.

Fast way to turn a /24 into a short list of live targets.

CYBERA4U
CYBER ACADEMY FOR U

When ICMP is blocked, probe another way

Flag	Probe	Good for
`-PS<ports>`	TCP SYN ping	Hosts behind an ICMP-blocking firewall
`-PA<ports>`	TCP ACK ping	Mapping stateful firewall behavior
`-PU<ports>`	UDP ping	Hosts that ignore TCP probes
`-PE / -PP / -PM`	ICMP echo / timestamp / mask	Classic ICMP where it is allowed

Example: `nmap -sn -PS22,80,443 192.168.56.0/24`

CYBERA4U
CYBER ACADEMY FOR U

-Pn treats every host as up

Default

- Host discovery runs first
- Skips hosts that look down
- Faster, but can miss filtered hosts

-Pn (no ping)

- Assumes every host is online
- Port-scans all of them anyway
- Use when ICMP is fully blocked

-Pn is slower across a /24, but it finds hosts that silently drop discovery probes.

CYBERA4U
CYBER ACADEMY FOR U

Turn name resolution off for speed

kali@kali: ~

```
┌──(kali㉿kali)-[~]
└─$ nmap -sn -n 192.168.56.0/24
# -n : never do reverse-DNS lookups
Nmap scan report for 192.168.56.102
Host is up.  (no name resolved)
```

-n no DNS

Skips slow lookups — faster scans

-R force DNS

Resolve even hosts that look down

In an isolated lab there is no DNS server, so -n keeps every scan fast and clean.

CYBERA4U
CYBER ACADEMY FOR U

Your turn — run it against the lab

```
TARGET Metasploitable 2 @ 192.168.56.102 NETWORK 192.168.56.0/24 (host-only)
```

1. Sweep the subnet with sudo arp-scan -l and note each MAC.
2. Run nmap -sn 192.168.56.0/24 and list the hosts that are up.
3. Re-run the ping sweep with -n and watch it speed up.
4. Try nmap -sn -PS22,80 192.168.56.102 (TCP SYN ping).
5. Explain when you would reach for -Pn.

No solutions on this slide — work through each task on your own Kali VM.

CYBERA4U
CYBER ACADEMY FOR U

Three things to remember

1

Discover hosts before ports

Turn a /24 into a short list of live targets

2

On the LAN, ARP is the truth

Layer-2 discovery cannot be firewalled away

3

Adapt the probe to the defense

-PS/-PA/-PU and -Pn get past blocked ICMP

CYBERA4U
CYBER ACADEMY FOR U

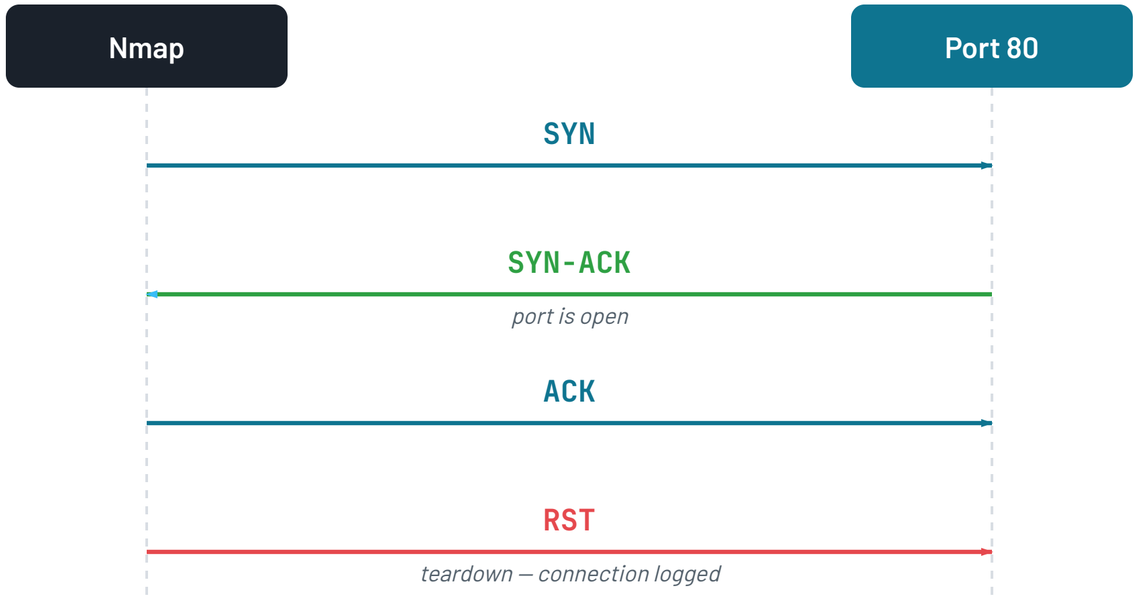
>_

LESSON 04

Identifying Open Ports and Running Services

CYBERA4U
CYBER ACADEMY FOR U

-sT completes the full handshake



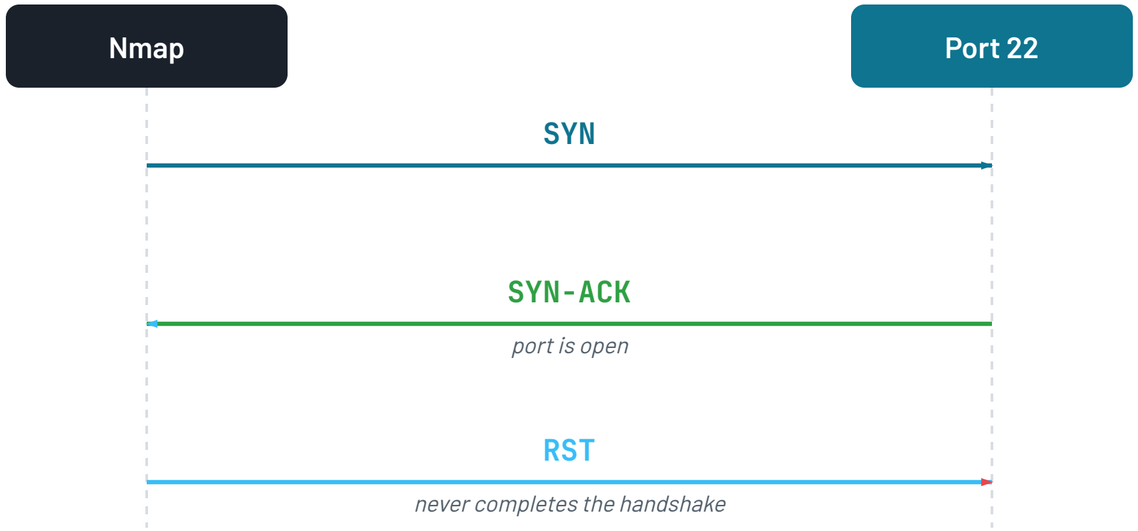
-sT

- \+ Uses the OS connect() call
- \+ No root privileges required
- \+ Completes handshake — easy to log

The fallback scan when you cannot run as root. Reliable, but the loudest TCP option.

CYBERA4U
CYBER ACADEMY FOR U

-sS is half-open and the default



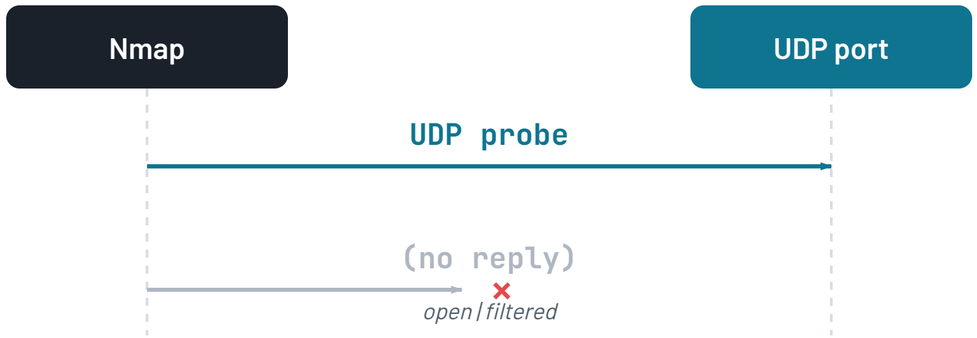
-sS (default as root)

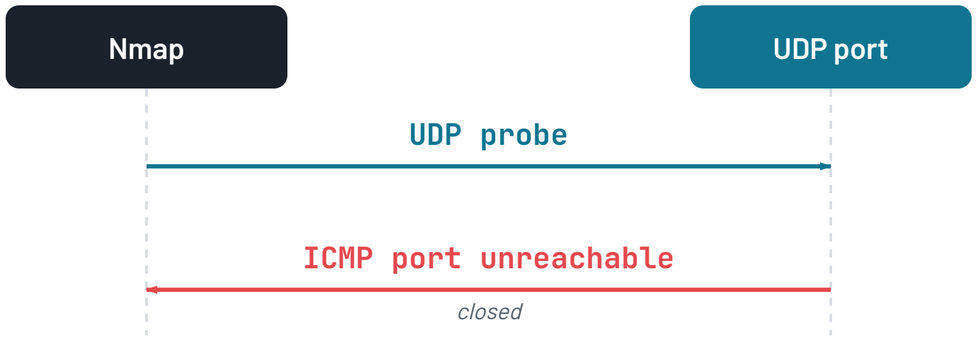
+ **Sends RST before the handshake ends**
+ **Faster and quieter than -sT**
+ **Needs raw-socket (root) access**

Because the connection never opens, many basic loggers never record it.

CYBERA4U
CYBER ACADEMY FOR U

-sU is slow — and here is why





No response is ambiguous, so Nmap waits and retransmits — that is why UDP scans crawl.

Stealth / legacy TCP probes: `-sF` FIN `-sN` NULL `-sX` Xmas

CYBERA4U
CYBER ACADEMY FOR U

What each port state really means

State	What Nmap saw	Meaning
`open`	SYN-ACK came back	A service is listening
`closed`	RST came back	Reachable, nothing listening
`filtered`	No reply, or ICMP unreachable	A firewall dropped the probe
`unfiltered`	RST to an ACK probe	Reachable, state still unknown
`open|filtered`	Silence on a UDP probe	Nmap cannot tell which

open and filtered are the two states that drive every decision that follows.

CYBERA4U
CYBER ACADEMY FOR U

Scan the right ports, not all of them

`(none)`	Top 1000 ports	e.g. `nothing — the default`
`-p-`	All 65,535 ports	e.g. `-p-`
`-p`	A specific list	e.g. `-p 21,22,80,445`
`-F`	Fast: top 100 ports	e.g. `-F`
`--top-ports`	The N most common	e.g. `--top-ports 20`

CYBERA4U
CYBER ACADEMY FOR U

A SYN scan against Metasploitable 2

kali@kali: ~

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sS -T4 192.168.56.102
21/tcp   open  ftp
22/tcp   open  ssh
80/tcp   open  http
445/tcp  open  microsoft-ds
3306/tcp open  mysql
6667/tcp open  irc       ... 23 ports open
```

Classic open ports

21 · 22 · 23 · 25 · 53 · 80 · 139 · 445 · 3306 · 5432 · 6667 · 8180

`-T4` speeds it up in the lab

`--min-rate 1000`

pushes a floor on packets per second.

CYBERA4U
CYBER ACADEMY FOR U

Your turn — run it against the lab

```
TARGET Metasploitable 2 @ 192.168.56.102 NETWORK 192.168.56.0/24 (host-only)
```

1. Run a TCP connect scan (-sT) and a SYN scan (-sS); compare.
2. Scan all ports with sudo nmap -sS -p- 192.168.56.102.
3. Scan only -p 21,22,80,445 and read each port state.
4. Try a UDP scan (-sU) on a few ports and time it.
5. List every open port you found on the target.

No solutions on this slide — work through each task on your own Kali VM.

CYBERA4U
CYBER ACADEMY FOR U

Three things to remember

1

SYN scan is the default workhorse

Half-open, fast, and needs root for raw sockets

2

State tells you where to look

open invites, filtered means a firewall is in the way

3

Metasploitable 2 is wide open

Over twenty services are listening and exposed

CYBERA4U
CYBER ACADEMY FOR U

>_

LESSON 05

Identifying Operating Systems and Software Versions

CYBERA4U
CYBER ACADEMY FOR U

-sV names the software behind each port

kali@kali: ~

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV 192.168.56.102
21/tcp   open  ftp     vsftpd 2.3.4
22/tcp   open  ssh     OpenSSH 4.7p1 Debian
80/tcp   open  http    Apache httpd 2.2.8
139/tcp  open  smb     Samba smbd 3.x
3306/tcp open  mysql   MySQL 5.0.51a
```

`-sV` probes each

open port and matches banners to a service database.

`--version-intensity 0-9`

Higher = more probes, more certainty, more noise.

Version numbers are the single most useful output of a scan.

CYBERA4U
CYBER ACADEMY FOR U

-O fingerprints the TCP/IP stack

```
kali@kali: ~

┌──(kali㉿kali)-[~]
└─$ sudo nmap -O 192.168.56.102
Device type: general purpose
Running: Linux 2.6.X
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
```

How it works

Compares subtle TCP/IP quirks to a fingerprint database.

`--osscan-guess`

Takes a best guess when the match is not exact.

OS detection needs root and at least one open and one closed port to be reliable.

CYBERA4U
CYBER ACADEMY FOR U

Grab a banner by hand with netcat

kali@kali: ~

```
┌──(kali㉿kali)-[~]
└─$ nc 192.168.56.102 21
220 (vsFTPd 2.3.4)

┌──(kali㉿kali)-[~]
└─$ nc 192.168.56.102 22
SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1
```

Manual = control

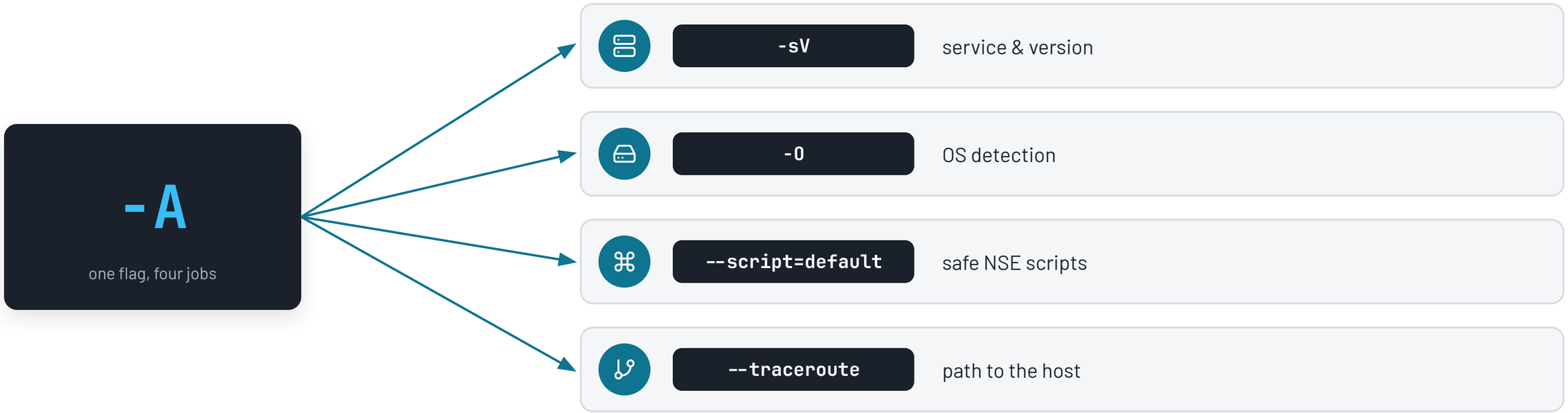
Connect to a port and read what it announces.

`nmap --script banner`

Automates banner grabbing across many ports.

CYBERA4U
CYBER ACADEMY FOR U

-A bundles the loud, thorough scan



Thorough, but very loud — reach for -A when stealth is not a concern.

CYBERA4U
CYBER ACADEMY FOR U

NSE turns Nmap into a scanner platform

`default`
safe, run with -sC / -A

`safe`
no impact on the target

`vuln`
checks for known flaws

`auth`
authentication testing

```
kali@kali: ~

┌──(kali㉿kali)-[~]
└─$ nmap --script=http-title \
    192.168.56.102

80/tcp open http
|_http-title: Metasploitable2
```

`--script=<name|category>` selects what to run

`vuln` scripts move toward enumeration — that is Module 06.

CYBERA4U
CYBER ACADEMY FOR U

A version is a lead, not an exploit

Service found	Version	Why it is worth a closer look
FTP	`vsftpd 2.3.4`	Build shipped with a known backdoor
IRC	`UnrealIRCd`	A tampered release was distributed
SMB	`Samba 3.x`	Several remote code-execution CVEs
HTTP	`Apache 2.2.8`	Years out of date — many issues
DB	`MySQL 5.0.51a`	Weak defaults, old and exposed

We note these as leads here. Confirming and exploiting them is the job of Module 06.

CYBERA4U
CYBER ACADEMY FOR U

Your turn — run it against the lab

```
TARGET Metasploitable 2 @ 192.168.56.102 NETWORK 192.168.56.0/24 (host-only)
```

1. Run nmap -sV 192.168.56.102 and record every version string.
2. Run sudo nmap -O and note the OS family Nmap reports.
3. Banner-grab port 21 and port 22 with netcat.
4. Run the aggressive scan nmap -A against the target.
5. Pick one version and write why it is worth investigating.

No solutions on this slide — work through each task on your own Kali VM.

CYBERA4U
CYBER ACADEMY FOR U

Three things to remember

1

-sV and -O build the fingerprint

Software versions plus an OS family identify the host

2

-A is thorough but loud

It bundles version, OS, default scripts and traceroute

3

A version is a lead

Map it to attack surface — exploit it in Module 06

CYBERA4U
CYBER ACADEMY FOR U

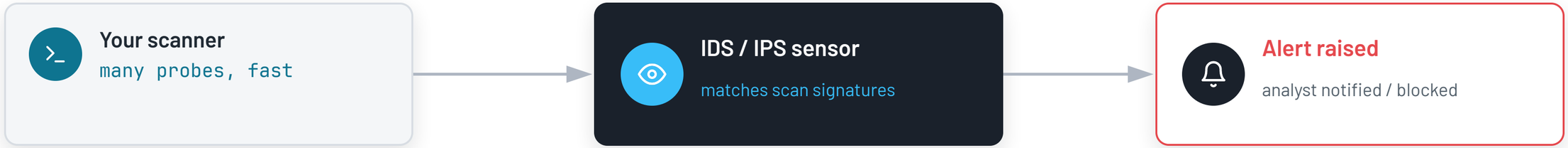
>_

LESSON 06

Techniques to Bypass Detection Systems

CYBERA4U
CYBER ACADEMY FOR U

Defenders watch for the shape of a scan



Evasion here means testing and tuning those detection controls — always inside the authorized lab.

CYBERA4U
CYBER ACADEMY FOR U

Slow down to stay under the thresholds

QUIETER / SLOWER

NOISIER / FASTER

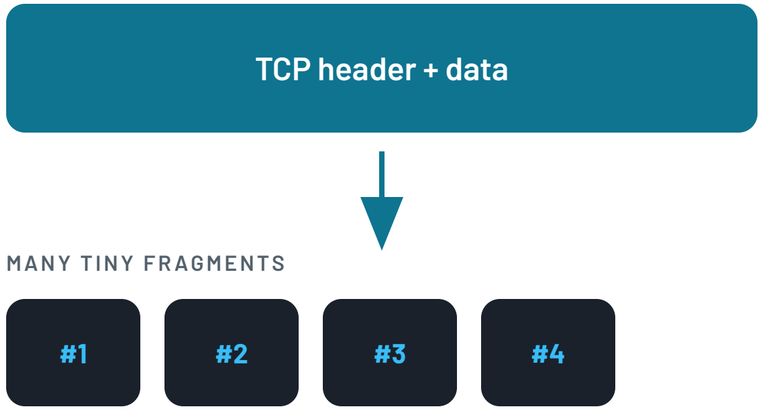


+ **-T0 / -T1 — paranoid and sneaky timing**
  spreads probes far apart to dodge rate-based rules
+ **—scan-delay 1s — a fixed gap between probes**
  defeats "N connections per second" thresholds
+ **—randomize-hosts — shuffle the scan order**
  breaks the tidy sequential sweep a sensor expects

CYBERA4U
CYBER ACADEMY FOR U

Split a probe to break its signature

ONE PROBE



...reassembled only at the target

`-f` split into 8-byte fragments

Use -ff to fragment even more aggressively.

`--mtu 16` set a custom fragment size

Must be a multiple of 8.

Older or misconfigured sensors inspect each fragment alone and miss the pattern.

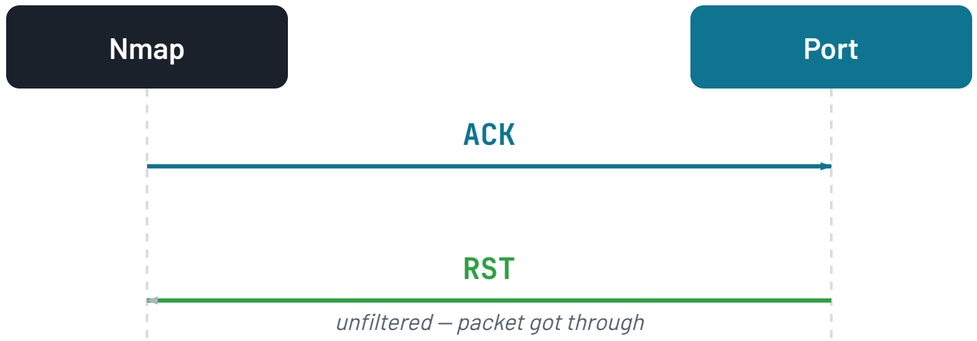
CYBERA4U
CYBER ACADEMY FOR U

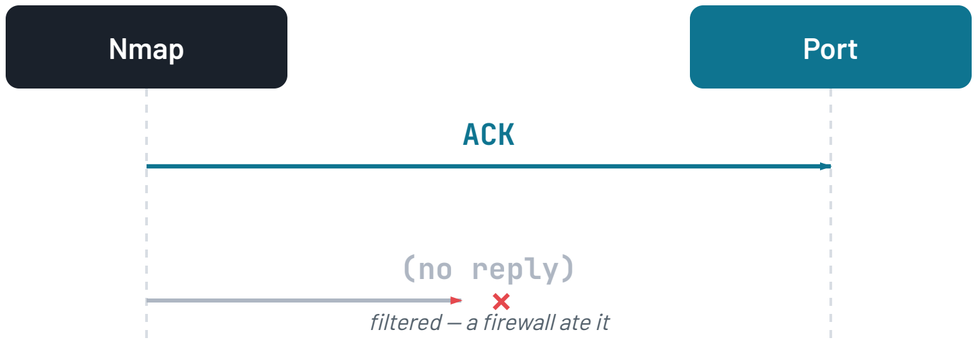
Pad packets and pick quiet ports

`--data-length 25`	Append random bytes so probes do not match a fixed-size signature
`--source-port 53`	Appear to come from DNS — a port many firewalls trust
Choose uncommon ports	Scan only quiet, less-monitored services instead of the top 1000
Spread probes over time	Combine with slow timing so no burst ever stands out

CYBERA4U
CYBER ACADEMY FOR U

-sA maps the firewall, not the ports





`-sA` does not find open ports — it reveals which ports a stateful firewall is filtering.

Reading filtered vs. unfiltered tells you where the firewall rules sit.

CYBERA4U
CYBER ACADEMY FOR U

Same goal, very different footprint

Goal	Noisy way	Quieter way
Port scan	`-sS -T4`	`-sS -T1 --scan-delay`
Host order	sequential sweep	`--randomize-hosts`
Packets	default size	`-f --data-length`
Speed	`--min-rate 1000`	slow, spread out

Honest limit: modern IDS/IPS and EDR still catch most of these. Evasion is for testing defenses, never a guarantee.

CYBERA4U
CYBER ACADEMY FOR U

Your turn — run it against the lab

```
TARGET Metasploitable 2 @ 192.168.56.102 NETWORK 192.168.56.0/24 (host-only)
```

1. Scan once with -T4, then with -T1; compare the timing.
2. Add —randomize-hosts to a /24 sweep and watch the order.
3. Fragment a scan with -f against 192.168.56.102.
4. Try —source-port 53 and —data-length 25 together.
5. Run an ACK scan (-sA) and read filtered vs. unfiltered.

No solutions on this slide — work through each task on your own Kali VM.

CYBERA4U
CYBER ACADEMY FOR U

Three things to remember

1

Scans have a recognizable shape

Speed, order and packet size all betray a scan

2

Slower and smaller is quieter

Timing, fragmentation and padding shrink the footprint

3

Evasion is for testing, not magic

Modern defenses still detect most of these techniques

CYBERA4U
CYBER ACADEMY FOR U

>_

LESSON 07

Manipulating Source Traffic

CYBERA4U
CYBER ACADEMY FOR U

Change how your probes appear to arrive

Who sent it?

decoys hide the real source among many

Which host?

an idle zombie makes the scan look like someone else

From where?

spoofed IP, source port and MAC reshape the origin

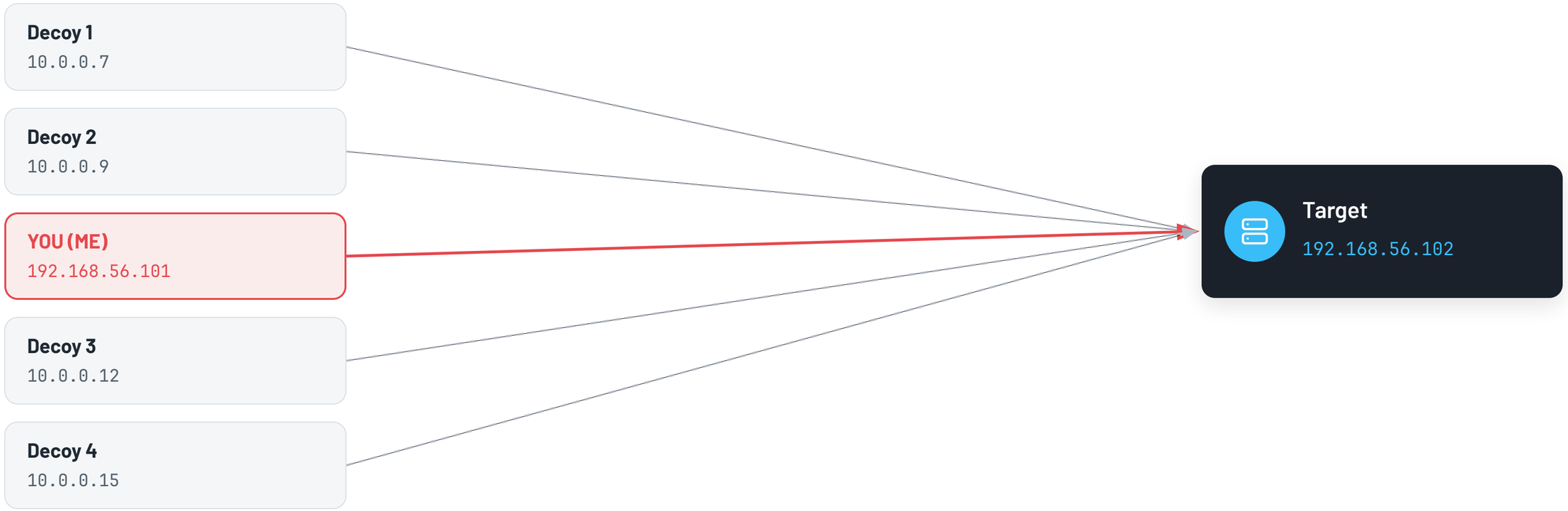
Through what?

proxies route probes via intermediaries

Framed as testing how defenses attribute and filter traffic — never to evade accountability.

CYBERA4U
CYBER ACADEMY FOR U

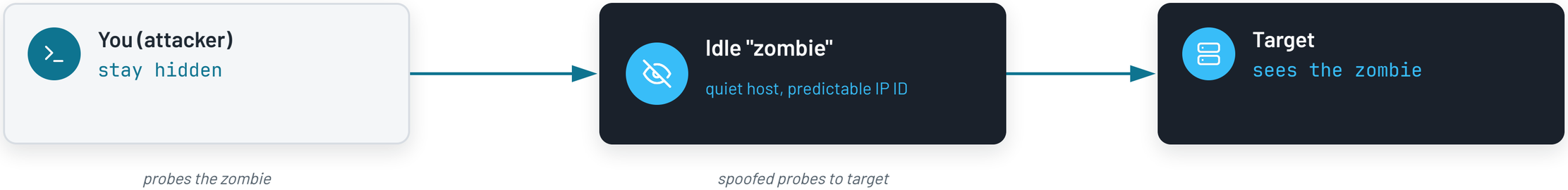
Hide the real source in a crowd (-D)




```
nmap -D 10.0.0.7,10.0.0.9,ME,10.0.0.12 192.168.56.102
```


CYBERA4U
CYBER ACADEMY FOR U

-sI borrows a zombie host's identity



How: Nmap reads the zombie's IP ID counter to infer the target's port state. It needs a genuinely idle host with predictable IP IDs — which is rare.

CYBERA4U
CYBER ACADEMY FOR U

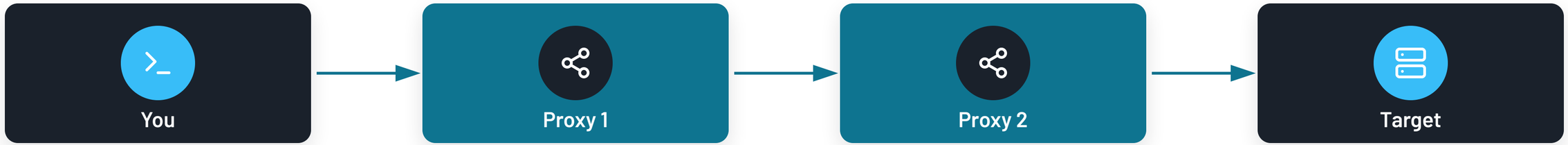
Reshape the source address and port

Flag	Does what	Note
`-S <ip>`	Spoof the source IP address	Replies will not return to you
`-g / --source-port`	Send from a fixed source port	Pose as 53 (DNS) or 80 (HTTP)
`--spoof-mac`	Forge the source MAC address	Works on the local segment only
`-e <iface>`	Pick the network interface	Send from eth1 on the lab net

`-S` *only tests ingress filtering — replies go to the spoofed host, not back to you.*

CYBERA4U
CYBER ACADEMY FOR U

Route probes through intermediaries



`--proxies` chains HTTP/SOCKS proxies; `proxychains nmap …` does the same at the OS level.

The target sees the last proxy, not you — useful for testing how defenses attribute traffic.

CYBERA4U
CYBER ACADEMY FOR U

Why most spoofing gets dropped

Spoofing the source

- Replies never come back to you
- Egress filtering blocks forged IPs
- Anti-spoofing (BCP 38) drops them

What actually survives

- Decoys among real, routable sources
- Proxies that return traffic to you
- Source-port tricks on weak firewalls

Every one of these is countered by the defenses in **Lesson 08**.

CYBERA4U
CYBER ACADEMY FOR U

Your turn — run it against the lab

```
TARGET Metasploitable 2 @ 192.168.56.102 NETWORK 192.168.56.0/24 (host-only)
```

1. Run a decoy scan: nmap -D RND:5 192.168.56.102.
2. Place ME explicitly in a -D decoy list and observe.
3. Scan with —source-port 53 against the target.
4. Try —spoof-mac 0 to use a random vendor MAC.
5. Explain why -S alone will not return results to you.

No solutions on this slide — work through each task on your own Kali VM.

CYBERA4U
CYBER ACADEMY FOR U

Three things to remember

1

You can reshape the source

Decoys, zombies, spoofed IPs, ports, MACs and proxies

2

Spoofing rarely returns data

If replies cannot reach you, the scan tells you nothing

3

Attribution tests the defense

Each trick maps to a control you will meet in Lesson 08

CYBERA4U
CYBER ACADEMY FOR U

>_

LESSON 08

Defensive Measures Against Network Discovery

CYBERA4U
CYBER ACADEMY FOR U

Four ways to blunt a network scan

Detect it

spot the scan as it happens

Reduce exposure

close ports, segment the network

Harden the perimeter

default-deny, anti-spoofing, rate limits

Deceive

honeypots and tarpits catch and delay

The same techniques from Lessons 06–07 become the signals a defender learns to watch.

CYBERA4U
CYBER ACADEMY FOR U

Every technique leaves a trace in the logs

Scanner did this	The signal it produced	Caught by
`SYN scan (-sS)`	Many SYNs, no completed handshakes	IDS signature / flow analysis
`Full /24 sweep`	One source touches many hosts	Rate / anomaly detection
`-T0 / -T1 slow scan`	Odd, long-lived low-rate probing	Long-window correlation
`Fragmented -f`	Unusual tiny fragments	Reassembly on modern IPS
`Decoys -D`	Burst from many IPs at once	Still logged and alerted

Snort and Suricata ship rules for exactly these patterns — logging and alerting turn them into action.

CYBERA4U
CYBER ACADEMY FOR U

Shrink what a scanner can even find

Close unused ports	If nothing listens, there is nothing to discover
Host-based firewalls	iptables / nftables, or Windows Firewall, default-deny
Segmentation & VLANs	A scanner on one segment cannot reach the others
Disable risky services	Turn off telnet, rsh, old SMB — the Metasploitable set

CYBERA4U
CYBER ACADEMY FOR U

Harden the edge against probing

Stateful firewall, default-deny	Drop anything you did not explicitly allow
Egress + anti-spoofing (BCP 38)	Block forged source IPs leaving or entering
Rate-limit ICMP and new flows	Starve ping sweeps and fast port scans
Centralized logging & alerting	Feed firewall denies to a SIEM that watches

CYBERA4U
CYBER ACADEMY FOR U

Catch and slow scanners on purpose



Honeypots

- Fake services that look real
- Any touch is, by definition, suspicious
- Reveal a scanner early and loudly



Tarpits

- Answer very, very slowly on purpose
- Each connection ties up the scanner
- Turn a fast sweep into a long wait

Deception does not replace the controls above — it buys time and high-confidence alerts.

CYBERA4U
CYBER ACADEMY FOR U

The lab target vs. a hardened host

Control	Metasploitable 2	Hardened host
Open ports	**20+ listening**	**Only what is needed**
Host firewall	**none — allow all**	**default-deny**
ICMP	**replies freely**	**rate-limited**
Logging	**off / none**	**scans alerted to a SIEM**
Patch level	**years out of date**	**current & supported**

Discovery is hardest against a host that is minimal, firewalled, patched and watched.

CYBERA4U
CYBER ACADEMY FOR U

Your turn — run it against the lab

```
TARGET Metasploitable 2 @ 192.168.56.102 NETWORK 192.168.56.0/24 (host-only)
```

1. List the open ports on Metasploitable 2 you would close first.
2. Write an iptables/nftables default-deny rule for the host.
3. Describe the log signature a -sS sweep would leave.
4. Name one Snort/Suricata rule category that catches scans.
5. Explain how a tarpit slows an attacker's sweep.

No solutions on this slide — work through each task on your own Kali VM.

CYBERA4U
CYBER ACADEMY FOR U

Three things to remember

1

Detect, then reduce, then harden

Logging, closed ports and default-deny do the heavy lifting

2

Anti-spoofing defeats Lesson 07

BCP 38 and egress filtering drop forged traffic

3

A quiet host is a hard target

Minimal, patched and watched beats any evasion trick

CYBERA4U
CYBER ACADEMY FOR U

Host discovery and port scanning

Goal	Flag	Example against the lab
Ping sweep — live hosts	`-sn`	`nmap -sn 192.168.56.0/24`
Layer-2 ARP sweep	`arp-scan`	`sudo arp-scan -l`
Treat every host as up	`-Pn`	`nmap -Pn 192.168.56.102`
TCP connect scan	`-sT`	`nmap -sT 192.168.56.102`
SYN (half-open) scan	`-sS`	`sudo nmap -sS 192.168.56.102`
UDP scan	`-sU`	`sudo nmap -sU 192.168.56.102`
All 65,535 ports	`-p-`	`nmap -p- 192.168.56.102`
A specific port list	`-p`	`nmap -p 21,22,80,445 192.168.56.102`
Fast — top 100 ports	`-F`	`nmap -F 192.168.56.102`

CYBERA4U
CYBER ACADEMY FOR U

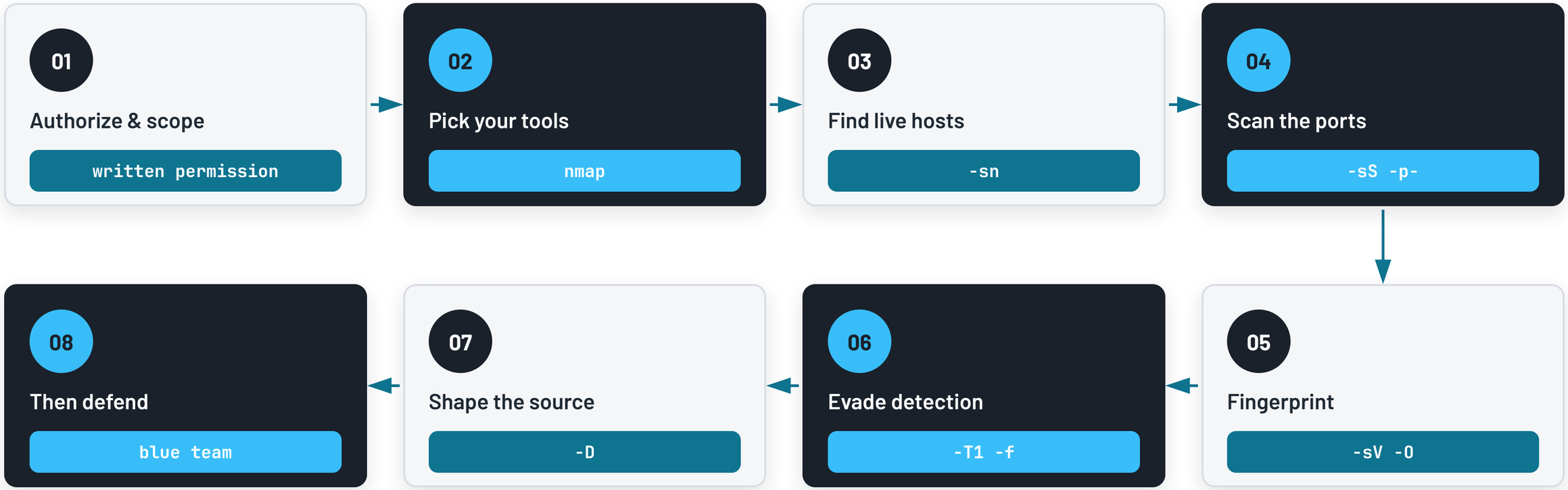
Fingerprinting, scripts, evasion and output

Goal	Flag	Example against the lab
Service & version	`-sV`	`nmap -sV 192.168.56.102`
OS detection	`-O`	`sudo nmap -O 192.168.56.102`
Aggressive (all-in-one)	`-A`	`nmap -A 192.168.56.102`
Run an NSE script	`--script`	`nmap --script=http-title 192.168.56.102`
Fast lab timing	`-T4`	`nmap -sS -T4 192.168.56.102`
Stealth timing	`-T1`	`nmap -sS -T1 --scan-delay 1s 192.168.56.102`
Fragment probes	`-f`	`nmap -f 192.168.56.102`
Decoy scan	`-D`	`nmap -D RND:5 192.168.56.102`
Save all formats	`-oA`	`nmap -sS -oA scan 192.168.56.102`

CYBERA4U
CYBER ACADEMY FOR U

>_ MODULE SUMMARY

The eight lessons, as one scan workflow



One authorized target, one disciplined pass — from permission to a hardened defense.

CYBERA4U
— CYBER ACADEMY FOR U

Think it through — no answers on the slide

1

SCENARIO 01 · HOST DISCOVERY

You are authorized to scan 192.168.56.0/24, but the target drops all ICMP. Which Nmap options still let you find the live hosts, and why does ARP work on this segment?

2

SCENARIO 02 · PORT STATE

A SYN scan reports 80/tcp as filtered, not closed. What does "filtered" tell you about the path to that port, and which scan type would help you map the firewall rules?

CYBERA4U
CYBER ACADEMY FOR U

Think it through — no answers on the slide

3

SCENARIO 03 · METHODOLOGY

nmap -sV reports vsftpd 2.3.4 on port 21 of the lab target. What is your next step in the methodology — and what must you NOT do yet, given the scope of this module?

4

SCENARIO 04 · FOOTPRINT

You must scan quietly to test the SOC's detection. Name three options that shrink your footprint, and explain why none of them is a guarantee against modern defenses.

CYBERA4U
CYBER ACADEMY FOR U

Think it through — no answers on the slide

5

SCENARIO 05 · BLUE TEAM

As the defender, your logs show one source sending many SYNs to many ports in a few seconds. Name two controls that would detect this activity, and two that would reduce the damage it can do.

Work each scenario against your own lab, then compare with a peer.

CYBERA4U
CYBER ACADEMY FOR U

END OF MODULE 05

Next: Module 06

Service & Application Enumeration

>_ from open ports to a foothold

INSTRUCTOR

Mo'tasem Abu Baha'

CYBERA4U
CYBER ACADEMY FOR U